

Ten findings, all closed

Every finding is now fixed or deliberately left, each one re-tested against a running API. Including the two places this report was wrong the first time, and three problems the testing uncovered that were never on the list.

Date 19 August 2026 **Merged** main @ d2fda5f (PR #88) **Checks** ~180, then re-run after each fix
Supersedes revision 1

Result

Where the ten stand

You asked for all ten, including the three I had advised against. All ten are done — two of those three implemented in a better form than the option described, explained below.

7

FIXED

Code changed, merged, and re-tested against a running API.

3

RESOLVED OTHERWISE

One was environment, one was already correct, one needs your decision.

3

NEW, UNASKED

Turned up while verifying. One of them was live.

	FINDING	STATUS	PROOF
1	16-hour daily timesheet cap could be exceeded	FIXED	24h → 5h under the same test
2	Preview app pointed at the live database	FIXED	Starts safe with no overrides
3	Duplicate leave requests, same day	FIXED	4 → 1
4	Duplicate work-from-home requests	FIXED	4 → 1
5	Won deal with no client went untracked	FIXED	Badge + column count
6	Shared HR login had no reporting line	WAS WRONG	Not in production at all
7	Logout left the session usable 15 minutes	FIXED	Dies at once; phone stays in
8	Departments differing only by capitals	FIXED	4-6 → 1
9	Team-list creation returned the wrong thing	FIXED	Returns the list
10	Validation answered before permission	FIXED	403 before 400, on appraisals

Findings 1, 3, 4 and 8 were one bug wearing four hats, so they got one fix rather than four patches: a transaction-scoped lock keyed as narrowly as the rule it protects. Each was reproduced deliberately with concurrent requests before the fix, and the identical test re-run after.

Proof

Before and after, same tests

Every number below comes from running the same concurrent requests twice — once against the old build, once against the new.

TEST	BEFORE	AFTER
Four simultaneous 6-hour timesheet entries, one day	24 hours accepted	5 hours — cap held
Six concurrent entries totalling 30 hours	would all land	5 hours
Sequential 8h, then 6h, then 4h (<i>must still work</i>)	—	14h in, the 4h refused
Four simultaneous leave requests, one Wednesday	4 created	1
Four simultaneous WFH requests, one day	4 created	1
Six department names differing only in capitals	4-6 created	1, five refused with 409
Log out of one session, two open	both still worked	that one dead, the other alive
Sign out everywhere (<i>must still work</i>)	—	both dead
Outsider probes an appraisal with a bad field	400 naming the field	403, nothing revealed
Owner sends a bad field (<i>must still be told</i>)	—	400 naming the field

The three you asked for that I had advised against

You chose them, so they are done. Two are implemented differently from how the option described them, because there was a version without the downside I had objected to. That is a change to my proposal, so it is stated rather than buried.

07 Logout — done, but without signing out your phone

FIXED

THE OPTION SAID "Make logout revoke the access token immediately (signs you out on every device at once)."

WHY I OBJECTED Twenty-seven people signing out of a desk and losing their phone session daily is a worse cost than the risk it removes.

WHAT I DID INSTEAD Gave the access token the id of its own sign-in — the refresh-token family, which survives every rotation of that session. Signing out revokes that family; the middleware then refuses a token whose session is gone.

RESULT You get the immediate revocation you asked for, and other devices are untouched. **SIGN OUT EVERYWHERE** still clears everything.

SAFE TO DEPLOY Tokens issued before this carry no session id and stay valid until they expire, so shipping it does not sign the firm out.

10 Validation before permission — the premise was wrong

FIXED

THE OPTION SAID "Reorder validation vs permission checks across all 363 routes."

THE TRUTH That was not the cause, and I had it wrong in revision 1 too. The framework already checks permission before validating. These particular routes do their ownership check *inside the service*, which necessarily runs after validation — so the 400 arrived first.

WHAT I DID Added a guard to the eleven individual-appraisal routes, which runs before validation. No reordering, no touching the other 350.

WHY ONLY APPRAISALS The information exposed elsewhere is field names, which are already in the browser bundle. An appraisal is different: it carries somebody's rating and their manager's written remarks, so even confirming one exists is worth refusing.

09 Team list creation

FIXED

DONE AS DESCRIBED Creating a list returns the list, not the whole team space. The screen refetches separately, so nothing depended on the old shape — verified the created id is usable immediately.

Where revision 1 was wrong

Two of the ten did not survive contact with the production database. Recording that is worth more than letting them quietly disappear.

06

The shared HR account does not exist in production

I WAS WRONG

I REPORTED	A shared login approving leave and reading personal details with no attribution, showing on the org chart with no reporting line.
ACTUALLY	<code>hr@squarkip.com</code> is NOT IN THE PRODUCTION DATABASE AT ALL. It exists only in the seeded scratch database I was testing against, where it has never been logged into and has approved nothing.
SHAVETA	Already has her own named HR account with the same role — which is the arrangement the finding was asking for.
ACTION	None. The finding was an artefact of my test data.

08

The department name race was real after all

CONFIRMED THEN FIXED

I SAID	In the earlier report, that it was theoretical and needed simultaneous requests.
TESTING	Reproduced it on the first attempt. Six concurrent requests created four departments.
NOTE	I had also proposed not fixing it, because a case-insensitive index would cause permanent schema noise. The transaction closes the race without any index, so that objection went away.

Three things the testing turned up

A Your demo link had been dead since 04:41		FIXED
WHAT	The tunnel process was running and its URL was unreachable — alive but not working, which is exactly what a process check misses. It had been in that state for about five hours.	
FIXED	Restarted. New link: drainage-ann-smallest-valium.trycloudflare.com , answering in under a second.	
WORTH KNOWING	There is no supervisor and no scheduled task, so nothing would have restarted it. It stays up until something disturbs it.	
B That demo is showing the product as it was on 7 August		YOUR CALL
WHAT	The stack behind the tunnel runs an API built on 7 AUGUST, with a database to match: no reporting lines at all, no deals table, no appraisal parameters, no optional holidays, no policies, and a Business Development role that exists with ZERO PERMISSIONS.	
NOT BROKEN	Old code and old data agree with each other, and the old screens never call the routes that are missing. It works — it is just twelve days behind.	
BUT	Nothing built in Phase 2 is visible there: no client ledger, no team spaces, no BD pipeline, no departments screen, no org chart, no appraisal parameters. Anyone shown that link is being shown August the 7th.	
TO FIX	That copy needs pulling, rebuilding and migrating — the same three steps as the server. It briefly interrupts the link, so it is your call when. The Contabo server is the copy that has been kept current.	
C A rate limit worth watching, not yet a problem		OBSERVATION
WHAT	The limit is 200 requests a minute per address. Each person is counted separately through the proxy — I checked that, and it is set up correctly.	
THE CATCH	It counts by address, and an office shares one. Twenty-seven people behind a single gateway share 200 a minute, which is about seven each.	
HONEST STATUS	Nobody has reported this, and I could not test it without knowing your office network. If anyone ever sees a sudden "too many requests" that clears after a minute, this is the first place to look, and the fix is to count per signed-in person rather than per address.	
CAPACITY IS FINE	Sixteen simultaneous sign-ins completed in 105 milliseconds with no errors.	

What this needs

Nothing unusual. Everything in this batch is application code.

```
ssh -p 2222 root@217.76.59.244
cd /opt/pdash
git pull origin main
docker compose up -d --build
```

No migration and no permission re-grant for this batch. The department migration from the previous batch is still additive and still safe — it de-duplicates names before creating its index, so it cannot fail on data already in your table.

What has not been done

1. **The stale demo copy** — flagged above. It is a deploy action that briefly interrupts the link, so it waits on you.
2. **Deploying any of this to Contabo** — the commands are above; the server is yours to restart.
3. **The GitHub token** shared earlier has now been used across several sessions and appears in the transcript. Worth revoking.